

# Ataque DHCP Spoofing — Documentación Técnica

**Autor:** Junior Javier Santos Perez

**Matrícula:** 2024-1599

**Herramienta:** dhcp\_spoofing\_v3.py

**Plataforma de laboratorio:** GNS3 + Kali Linux 2025.3

**Link video:** <https://www.youtube.com/watch?v=9nkW1iPMOMY>

**Enlace GitHub:** <https://github.com/juniorjaversantosperez/DHCP-Spoofing>

## Tabla de Contenidos

1. [Objetivo del Laboratorio](#)
2. [Objetivo del Script](#)
3. [Parámetros Utilizados](#)
4. [Requisitos para el Uso de la Herramienta](#)
5. [Descripción del Funcionamiento del Script](#)
6. [Documentación de la Red](#)
7. [Topología](#)
8. [Capturas de Pantalla](#)
9. [Medidas de Mitigación / Contramedidas](#)

## Objetivo del Laboratorio

Demostrar de forma práctica y controlada la ejecución de un ataque de **DHCP Spoofing (Rogue DHCP Server)** sobre una red simulada en GNS3, con el fin de:

- Comprender cómo un servidor DHCP falso puede envenenar la configuración de red de una víctima.
- Observar el proceso completo DISCOVER → OFFER → REQUEST → ACK manipulado por el atacante.
- Verificar que la víctima recibe una IP, gateway y DNS controlados por el atacante.
- Proponer e implementar contramedidas efectivas para mitigar el ataque.

## Objetivo del Script

El script `dhcp_spoofing_v3.py` implementa un **servidor DHCP falso (Rogue DHCP Server)** que responde a solicitudes DHCP legítimas antes que el servidor real, con el fin de:

- Asignar a la víctima una dirección IP dentro del rango de la red legítima.
- Entregar como **gateway falso** la IP del atacante (10.0.99.100), redirigiendo todo el tráfico de la víctima a través del atacante.
- Entregar como **DNS falso** la IP del atacante, permitiendo ataques de DNS Spoofing posteriores.
- Activar **IP Forwarding** para mantener conectividad y hacer el ataque transparente.
- Redirigir el tráfico DNS (puerto 53) mediante `iptables` hacia el puerto 5353 del atacante.

## Parámetros Utilizados

| Parámetro | Valor | Descripción                                             |
|-----------|-------|---------------------------------------------------------|
| Interfaz  | eth0  | Interfaz del atacante usada para el servidor DHCP falso |

| Parámetro       | Valor                      | Descripción                                               |
|-----------------|----------------------------|-----------------------------------------------------------|
| Servidor falso  | 10.0.99.100                | IP del atacante — actúa como servidor DHCP                |
| Gateway falso   | 10.0.99.100                | Gateway entregado a la víctima (apunta al atacante)       |
| DNS falso       | 10.0.99.100                | DNS entregado a la víctima (apunta al atacante)           |
| Subred          | 10.0.99.0/24               | Subred de la red objetivo                                 |
| IPs asignables  | 10.0.99.2 →<br>10.0.99.254 | Rango de IPs ofrecidas a víctimas (aleatorias)            |
| Tiempo de lease | 600s                       | Duración del arrendamiento DHCP asignado                  |
| IP asignada     | 10.0.99.125                | IP efectivamente entregada a la víctima en el laboratorio |
| Redirección DNS | Puerto 53 → Puerto 5353    | Regla iptables para interceptar consultas DNS             |

## Requisitos para el Uso de la Herramienta

### Sistema Operativo

- Kali Linux 2025.3 (o cualquier distribución Linux con soporte a raw sockets)

### Privilegios

- Ejecución como `root` o con `sudo` (necesario para bind en puerto 67/UDP y modificar iptables)

### Dependencias Python

```
# Requiere Scapy para construcción y envío de paquetes DHCP
pip install scapy
```

```
# Módulos de la librería estándar utilizados:
import socket
import struct
import threading
import subprocess
import os
```

## **Configuración del Sistema**

```
# IP Forwarding (el script lo activa automáticamente)
echo 1 > /proc/sys/net/ipv4/ip_forward

# Regla iptables para DNS (el script la aplica automáticamente)
iptables -t nat -A PREROUTING -p udp --dport 53 -j REDIRECT --to-port 5353
```

## **Entorno de Laboratorio**

- GNS3 con nodos Kali Linux (atacante y víctima)
- Router Cisco como gateway legítimo
- Switch L2 conectando todos los nodos
- La víctima debe solicitar IP por DHCP (`dhclient`)

## **Descripción del Funcionamiento del Script**

El script opera siguiendo el flujo estándar del protocolo DHCP, pero respondiendo de forma maliciosa:

### **Fase 1 — Inicialización**

El script levanta un servidor UDP en el puerto 67 (DHCP Server), activa IP Forwarding y configura la regla `iptables` para interceptar consultas DNS. Queda en espera de solicitudes broadcast de clientes DHCP.

## Fase 2 — DHCP DISCOVER

La víctima envía un broadcast DHCP DISCOVER solicitando configuración de red. El script detecta este mensaje antes que el servidor legítimo:

```
[→] DHCP DISCOVER desde 00:0c:29:a0:0a:51
```

## Fase 3 — DHCP OFFER (Falso)

El servidor falso responde con un DHCP OFFER que contiene una IP aleatoria del rango y los parámetros maliciosos:

```
[←] DHCP OFFER hacia 00:0c:29:a0:0a:51 → IP ofrecida:  
10.0.99.125
```

## Fase 4 — DHCP REQUEST

La víctima acepta la oferta y solicita formalmente la IP:

```
[→] DHCP REQUEST desde 00:0c:29:a0:0a:51 solicitando:  
10.0.99.125
```

## Fase 5 — DHCP ACK (Envenenamiento Confirmado)

El servidor falso confirma la asignación con los parámetros maliciosos:

```
[←] DHCP ACK hacia 00:0c:29:a0:0a:51  
  
✓ Cliente envenenado:  
    IP      : 10.0.99.125  
    Gateway : 10.0.99.100 ← (atacante)  
    DNS     : 10.0.99.100 ← (atacante)
```

## Resultado

La víctima queda con el atacante como gateway y DNS. Todo su tráfico de red y consultas DNS pasan por el atacante, quien puede interceptarlos, modificarlos o registrarlos.

Documentación de la Red

Tabla de Direccionamiento IP

| Nodo                             | Rol            | Interfaz | Dirección IP | Notas                               |
|----------------------------------|----------------|----------|--------------|-------------------------------------|
| kali-linux-2025.3-vmware-amd64-1 | Atacante       | eth0     | 10.0.99.100  | Servidor DHCP falso + Gateway falso |
| Clonekali-1                      | Víctima        | e0       | 10.0.99.125  | IP asignada por el servidor falso   |
| Switch-1                         | Switch L2      | e0/e1/e2 | N/A (L2)     | Cisco IOS IOSv Switch               |
| R1                               | Router/GW real | f0/0     | 10.0.99.1    | Gateway legítimo de la red          |

Protocolo Explotado

| Protocolo | Puerto    | Descripción                                                                    |
|-----------|-----------|--------------------------------------------------------------------------------|
| DHCP      | UDP 67/68 | Sin autenticación — cualquier servidor puede responder a solicitudes broadcast |
| DNS       | UDP 53    | Redirigido al atacante mediante iptables para DNS Spoofing                     |

Evidencia del Envenenamiento

| Parámetro  | Valor legítimo  | Valor entregado por atacante | Impacto                              |
|------------|-----------------|------------------------------|--------------------------------------|
| Gateway    | 10.0.99.1       | 10.0.99.100 (atacante)       | Todo el tráfico pasa por el atacante |
| DNS        | DNS legítimo    | 10.0.99.100 (atacante)       | Posible DNS Spoofing / Phishing      |
| IP cliente | Asignada por R1 | 10.0.99.125 (lease 600s)     | Víctima en red controlada            |

Topología

La topología fue diseñada e implementada en **GNS3** con los siguientes componentes:

```
[Clonekali-1 / Víctima]
10.0.99.125 (IP del atacante)
GW: 10.0.99.100 ← FALSO
DNS: 10.0.99.100 ← FALSO
    |
    | (e2 - Switch-1)
[Switch-1]-----[R1 / Gateway Real]
    |              f0/0 - 10.0.99.1
    |
    | (e1 - Switch-1)
    |
[kali-linux-2025.3 / Atacante]
10.0.99.100
Servidor DHCP Falso activo
IP Forwarding: ON
iptables DNS redirect: ON
```

La imagen de la topología se encuentra en la carpeta `/images/` del repositorio.

Capturas de Pantalla

Las capturas de pantalla se encuentran almacenadas en la carpeta `/images/` del repositorio.

| # | Archivo                                    | Descripción                                                                                                          |
|---|--------------------------------------------|----------------------------------------------------------------------------------------------------------------------|
| 1 | imagen_01_topologia.png                    | Topología del laboratorio en GNS3 con nombre y matrícula del estudiante                                              |
| 2 | imagen_02_servidor_dhcp_falso_iniciado.png | Script <code>dhcp_spoofing_v3.py</code> en ejecución — servidor DHCP falso activo, esperando clientes                |
| 3 | imagen_03_victima_ip_envenenada.png        | Víctima solicitando IP — primera asignación <code>10.0.99.6</code> luego <code>10.0.99.125</code> del servidor falso |

| # | Archivo                                  | Descripción                                                                                            |
|---|------------------------------------------|--------------------------------------------------------------------------------------------------------|
| 4 | imagen_04_intercambio_dhcp_completo.png  | Intercambio DHCP completo: DISCOVER → OFFER → REQUEST → ACK con cliente envenenado confirmado          |
| 5 | imagen_05_contramedida_dhcp_snooping.png | Contramedida aplicada en el switch: ip dhcp snooping + ip dhcp snooping trust en interfaz hacia router |

## Medidas de Mitigación / Contramedidas

### 1. DHCP Snooping en el Switch Cisco (Contramedida Principal)

```
Switch# configure terminal
Switch(config)# ip dhcp snooping
Switch(config)# ip dhcp snooping vlan 1
Switch(config)# no ip dhcp snooping information option
```

! Marcar solo el puerto hacia el router legítimo como confiable

```
Switch(config)# interface g0/0
Switch(config-if)# ip dhcp snooping trust
Switch(config-if)# ^Z
Switch# write
```

DHCP Snooping filtra mensajes DHCP OFFER y ACK en puertos no confiables, bloqueando completamente servidores DHCP falsos. **Es la contramedida más efectiva.**

### 2. Limitar Tasa de Paquetes DHCP por Puerto

```
Switch(config)# interface g0/1
Switch(config-if)# ip dhcp snooping limit rate 15
```

Limita el número de paquetes DHCP por segundo en puertos de acceso, mitigando también ataques de DHCP Starvation.

### 3. Dynamic ARP Inspection (DAI) — Complemento



```
Switch(config)# ip arp inspection vlan 1
```

Basado en la tabla de DHCP Snooping, valida que las IPs y MACs en paquetes ARP coincidan con asignaciones DHCP legítimas.

#### 4. Segmentación con VLANs

Aislar dispositivos de usuario en VLANs separadas reduce el dominio de broadcast, limitando el alcance de cualquier servidor DHCP falso a su propio segmento.

#### 5. Usar Direcccionamiento Estático en Dispositivos Críticos

Servidores, routers y dispositivos de infraestructura deben tener IPs estáticas para no depender de DHCP y no ser vulnerables a este ataque.

#### 6. Monitoreo y Detección

```
# Verificar gateway activo en el cliente
ip route show
# Verificar servidor DHCP que asignó la IP
cat /var/lib/dhcp/dhclient.leases
# En el switch, verificar tabla de snooping
Switch# show ip dhcp snooping binding
Switch# show ip dhcp snooping statistics
```

#### **Aviso Legal / Disclaimer**

Este laboratorio fue realizado en un entorno **completamente controlado y simulado** con fines académicos y de investigación en seguridad informática. El uso de estas técnicas fuera de entornos autorizados es ilegal y contrario a la ética profesional. El autor no se hace responsable del uso indebido de este material.